

Web Application Security - Theory Notes

1. OWASP Top 10 - 2021 Overview

The OWASP Top 10 is a standard awareness document for developers and web application security. It represents the most critical security risks to web applications. The 2021 edition includes the following categories:

- **Broken Access Control** - Failures in restricting what authenticated users can do.
- **Cryptographic Failures** (formerly "Sensitive Data Exposure") - Weak or absent encryption.
- **Injection** - Including SQL, NoSQL, OS, and LDAP injection.
- **Insecure Design** - Design flaws that lead to vulnerabilities.
- **Security Misconfiguration** - Default settings, error messages, and unpatched flaws.
- **Vulnerable and Outdated Components** - Using outdated libraries, frameworks, or plugins.
- **Identification and Authentication Failures** - Weak authentication or session management.
- **Software and Data Integrity Failures** - Issues like insecure CI/CD pipelines or unsigned code.
- **Security Logging and Monitoring Failures** - Lack of visibility and incident response.
- **Server-Side Request Forgery (SSRF)** - A server making unauthorized requests to internal systems.

2. Injection and Inclusion

Injection:

Injection flaws occur when untrusted data is sent to an interpreter as part of a command or query. It tricks the interpreter into executing unintended commands or accessing data without proper authorization.

Types:

- SQL Injection**
- Command Injection**
- NoSQL Injection**
- LDAP Injection**

Inclusion:

Inclusion vulnerabilities occur when an application includes a file without proper validation. These include:

- Local File Inclusion (LFI): Includes files on the server.**
- Remote File Inclusion (RFI): Includes external resources via URL.**

3. Cross-Site Scripting (XSS)

Cross-Site Scripting is a vulnerability that allows attackers to inject malicious scripts into web pages viewed by other users.

Types:

- Stored XSS: The script is stored on the server (e.g., in a database).**
- Reflected XSS: The script is reflected off a web server (e.g., in error messages).**

- **DOM-based XSS: The vulnerability exists in client-side scripts.**

Consequences:

- **Session hijacking**
- **Defacement**
- **Redirecting users**
- **Stealing sensitive data**

Mitigation:

- **Input validation and output encoding**
- **Content Security Policy (CSP)**
- **Escaping dynamic content**

4. Injection in Stored Procedures

Stored Procedures are routines stored in a database and executed with a call. If they are poorly written and take user input without validation, they can be vulnerable to SQL injection.

Example:

```
CREATE PROCEDURE getUser(@username VARCHAR)
AS
BEGIN
    EXEC('SELECT * FROM users WHERE username = ''' + @username + ''')
END
```

If an attacker inputs ' OR 1=1 --, it becomes:

```
SELECT * FROM users WHERE username = ' OR 1=1 --'
```

Prevention:

- Use parameterized queries.
- Avoid dynamic SQL inside stored procedures.
- Properly sanitize inputs.